Shams Security Ltd.

Rules of Engagement

Version 1.0

Supreme Security Limited

Dated: June 1, 2021

Revision History

Date	Version	Description	Author
June 1 , 2021	1.0	First version	Supreme Security Limited

1. INTRODUCTION

1.1. These Rules of Engagement (ROE) establish guidelines that determine how Shams Security Ltd. will conduct electronic and physical security tests for MegaCorpOne. They are based on the National Institute of Standards and Technology (NIST) Special Publication 800-42, "Guideline on Network Security Testing."

NIST SP 800-42 recommends that the Rules of Engagement "should include:

- Specific IP addresses/ranges to be tested
- Any restricted hosts (i.e., hosts, systems, subnets, not to be tested)
- A list of acceptable testing techniques (e.g. Social engineering, DOS, etc.) and tools (password crackers, network sniffers, etc.)
- Times when testing is to be conducted (e.g., during business hours, after business hours, etc.)
- Identification of a finite period for testing
- IP addresses of the machines from which penetration testing will be conducted, so that administrators can differentiate the legitimate penetration testing attacks from actual malicious attacks
- Points of contact for the penetration testing team, the targeted systems, and the networks
- Measures to prevent law enforcement from being called with false alarms (created by the testing)
- Handling of information collected by the penetration test team."

1.2. The following documents are incorporated by reference and, when used in conjunction with these Rules of Engagement, employ all NIST 800-42 ROE recommendations:

1.2.1. Engagement Letter, dated June 1 , 2021, between Supreme Security Limited and MegaCorpOne

1.2.2. Authorization to Perform Internet (External) Information Security Assurance Procedures, dated DD MMM YY, signed by Demo Company Limited

1.2.3. Authorization to Perform Network (Internal) Information Security Assurance Procedures, dated DD MMM YY, signed by Demo Company Limited

1.2.4. "Demo Company Limited Test Plan", dated DD MMM YY

1.3. A Glossary appears at the end of this document.

1.4. To implement NIST recommendations, the ROE

- describe the test objective(s), scope(s) and approach(es) we use
- prescribe when, where, how, against what assets and whom we conduct security testing
- designate both administrative and operational Points of Contact (POC) within the target organization and AC
- stipulate general and specifically permitted and prohibited behaviors
- stipulate specific procedures to be followed for various scenarios
- help ensure that our security tests achieve maximum effectiveness with minimal operational impact to the organization.

2. TEST OBJECTIVE

Determine the effectiveness of Demo Company Limited's security program in preventing or detecting unauthorized external and internal access to logical and physical assets. Specific objectives for each test are contained in the "Demo Company Limited Test Plan."

3. TEST SCOPE

Testing will commence on 1 May 2021 and conclude on 31 May 2021. External and internal logical testing and physical penetration testing (social engineering) will be performed. Not all logical and physical assets under MegaCorpOne control will be tested. Items approved for testing are described in paragraph 8, and items excluded from testing are described in paragraph 9. Additional restrictions may have been placed on sub-components of individual tests, and these additional restrictions are discussed in the "MegaCorpOne Test Plan.

4. GENERAL APPROACH

3.1. In agreement with MegaCorpOne, we will conduct only logical external testing from the Internet | only logical testing from inside the Demo Company Limited facilities | both external and internal logical testing of the Demo Company Limited network. Physical penetration testing is | is not a part of our testing approach.

3.1.1. Physical penetration testing will be conducted using various social engineering techniques to persuade or deceive ***MegaCorpOne*** employees to provide access to non-public facilities and information.

3.1.2. Our logical tests will be conducted covertly/overtly using NIST's

3.1.2.1. "Red Teaming" approach, where security testing is conducted without the knowledge of the organization's IT staff, but with full knowledge and permission of upper management. During covert testing, we will attempt to avoid detection by the MegaCorpOne IT staff and obscure our testing activities.

3.1.2.2. "Blue Teaming" approach, where security testing is conducted with the knowledge and consent of the organization's IT staff. We will announce testing windows, but not specific dates and times for testing, and report testing progress to the designated Demo Company Limited Point of Contact (POC). During our overt testing activity, we will monitor MegaCorpOne's response to our testing | and we will take no measures to avoid detection.

3.1.3. Logical testing will be performed:

3.1.3.1. As an "outsider" with no information about the client's computer systems.

3.1.3.2. With "some" knowledge of the client's computer system(s) in a role functionally equivalent to the knowledge of an average user.

3.1.3.3. With "complete" knowledge of the client's computer system(s) in a role functionally equivalent to an individual with administrative access.

3.1.4. We use a four-step approach:

3.1.4.1. Discovery (Information Gathering)

3.1.4.2. Vulnerability analysis

3.1.4.3. Exploitation

3.1.4.4. Reporting

3.1.5. Procedures for discovery, vulnerability analysis and exploitation vary by test and are contained in the "Demo Company Limited Test Plan."

3.2. Our reporting method compares Demo Company Limited's certification and accreditation process, implemented and approved security policies and procedures, and the results of security controls tests with NIST | FISCAM | FISMA | ISO/IEC 17799 | generally accepted best practices doctrine.

3.3. Comparing the results of our network security tests with Demo Company Limited's policies and procedures will highlight areas in which current practices are not congruent with approved policies and procedures. Comparing Demo Company Limited's policies, procedures and the results of our network security tests with established doctrine will spotlight areas in which the organization can improve its' security posture relevant to published standards.

3.4. Results of vulnerability scans will be taken at face value and will not be discounted for potential mitigating factors such as possibility of detection unless those factors were evaluated as part of the test.

4. TESTING TIMETABLE

4.1. External testing will begin prior to the start of internal testing.

4.2. Shams Security Limited will endeavor to complete external testing before the start of internal testing.

4.2.1. External testing commences 1 May, 2021and ends YYYY.

4.2.2. Internal testing commences XXXX and ends YYYY.

4.3. Physical penetration testing commences simultaneously with external logical testing and continues throughout the engagement, for as long as results are obtained.

4.4. Specific dates and times for each test are defined in the "MegaCorpOne Test Plan."

5. TESTING LOCATIONS

5.1. External testing will be executed from our offices in Tucson AZ. IP addresses and information on hosts used for external testing are located in "Authorization to Perform Internet (External) Information Security Assurance Procedures."

5.2. Internal testing will be executed from a location provided by MegaCorpOne. IP addresses and information on hosts used for internal testing are located in "Authorization to Perform Network (Internal) Information Security Assurance Procedures."

6. TOOLS AND METHODS

6.1. All tools used for information gathering, vulnerability assessment and penetration testing are generally accepted within the security community, have been used previously by AC, and vulnerability assessment/penetration testing team (VAPT) personnel have been trained in their use.

6.2. Electronic public domain information gathering is conducted using Internet search engines, WebFerret and NewsRover.

6.3. Logical vulnerability assessments are conducted using Tenable Nessus 3.0.2 (Direct Feed) or Internet Security Systems Internet Security Scanner (ISS).

6.4. Logical penetration tests are conducted using Immunity Inc. CANVAS 6.x, Metasploit Framework 2.x and other scripts/tools as required.

6.5. Physical penetration methods may include impersonation and persuasion using the telephone, email, postal mail and by personal visits to the organization. Attempts to gain unaccompanied physical access to restricted areas of the organization may include posing as utility workers, vendors, employees from another department, or technical and delivery personnel. We may attempt to recover discarded information by searching through bags of garbage discarded in public waste receptacles.

6.6. Exploitation is limited to demonstrating that a specific vulnerability exists and can be used to compromise network security. Only minimal exploitation actions will be taken, sufficient to validate a specific vulnerability. Once the vulnerability has been confirmed, no additional exploitation to escalate privileges or further compromise the host will be taken.

7. ITEMS TO BE TESTED

Logical

7.1.1 For a list of Internet (External) IP addresses to be tested, please see "Authorization to Perform Internet (External) Information Security Assurance Procedures."

7.1.2 For a list of network (Internal) IP addresses to be tested, please see "Authorization to Perform Network (Internal) Information Security Assurance Procedures."

Physical

7.1.3 Locations

7.1.3.1 Corporate Headquarters

7.1.3.2 East Side Branch

7.1.3.3 West Side Branch

7.1.4 Personnel

7.1.4.1 Members of the Help Desk Department

7.1.4.2 Members of the IT Staff

8. ITEMS NOT TO BE TESTED

Logical

8.1.1 See "Authorization to Perform Internet (External) Information Security Assurance Procedures"

8.1.2 See "Authorization to Perform Network (Internal) Information Security Assurance Procedures"

Physical

8.1.3 Locations

8.1.3.1 Data Center

8.1.3.2 North Branch

8.1.3.3 South Branch

8.1.4 Personnel

8.1.4.1 Senior Management

8.1.4.2 Tellers

9. DESIGNATED POINTS OF CONTACT

9.1. MegaCorpOne

9.1.1 Administrative Point(s) of Contact for coordination of Shams Security Limited inquiries and requirements

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

9.1.2 Operational Point(s) of Contact for logical testing

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

9.1.3 Operational Point(s) of Contact for physical penetration testing:

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

9.2. Supreme Security Limited Security Solutions

9.1.4 Administrative Point(s) of Contact for coordination of client inquiries and issues

Printed Name:	
Title:	

Responsibility Area	
Email:	
Contact No.:	
Address:	

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

9.1.5 Operational Point(s) of Contact for logical testing

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

9.1.6 Operational Point(s) of Contact for physical penetration testing

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

Printed Name:	
Title:	
Responsibility Area	
Email:	
Contact No.:	
Address:	

10. GENERAL RULES

Supreme Security Limited **WILL**:

10.1.1 Provide identification information for all machines used during vulnerability assessment and penetration testing to the designated POC.

10.1.2 Coordinate internal and external testing schedules with the client POC

10.1.3 Notify ONLY the designated POC at the target organization prior to commencement of testing

10.1.4 Inform client immediately upon verification of significant network weakness or vulnerability

10.1.5 Accomplish all testing within the specified time period(s)

10.1.6 Use only tools and techniques that have been used previously and with which the test team is familiar

10.1.7 Limit script uses to minimum actions required to validate detected vulnerability and remove scripts as soon as possible after the vulnerability has been validated

10.1.8 Provide a list of all changes made to systems configurations inherent in the verification of a vulnerability to Demo Company Limited operations staff and assist in the reversal of these changes as soon as feasible but no later than the conclusion of the test

10.1.9 Limit exploitation to establishing that a vulnerability exists that can be exercised with more aggressive and destructive techniques

10.1.10 Protect, and keep confidential, all user files and other data in Demo Company Limited's information systems in accordance with The Privacy Act of 1974 (5 USC 552a) and other applicable regulatory requirements.

10.1.11 Protect, and keep confidential, all information about test results such as information systems vulnerabilities and potential security compromises

10.1.12 Report any inadvertently disabled user accounts to MegaCorpOne POC immediately upon discovery of the disabled account

10.1.13 Present a list of potential exploits to the MegaCorpOne POC for authorization to exploit before the penetration test phase begins

10.1.14 Only exploit vulnerabilities approved by the MegaCorpOne POC

Supreme Security Limited **MAY**:

10.1.15 Scan all files and directories for file names and attributes

10.1.16 Open all system and software files

10.1.17 Add to or modify password files and user lists only where required to validate a detected vulnerability

10.1.18 Upload scripts or applications only for the purpose of validating a detected vulnerability.

10.1.19 Disclose test windows, but not specific test times and dates

Supreme Security Limited **WILL NOT**

10.1.20 Modify or delete system or data files

10.1.21 Redirect traffic within or outside of the MegaCorpOne network

10.1.22 Leave "footprints" on a system indicating access

10.1.23 Configure a system to allow future/return access

10.1.24 Intentionally conduct a denial of service attack against the organization's systems unless specifically authorized by written agreement with MegaCorpOne

10.1.25 Continue to exploit a validated vulnerability with more aggressive and destructive techniques once the existence of the vulnerability has been established

10.1.26 Intentionally disable user accounts

10.1.27 Disclose in advance to anyone other than the designated and authorized POC, the specific dates and times of testing

MegaCorpOne **WILL**

10.1.28 Provide a list of _____.

MegaCorpOne **MAY**

10.1.29 Provide a list of _____.

MegaCorpOne **WILL NOT**

10.1.30 Attempt to _____.

11. ALLOWED AND PROHIBITED PROCEDURES

MegaCorpOne authorizes or prohibits the specific procedures indicated in the table below by initials in either the "Yes" or "No" column:

Attack Methodology	**Permitted?**	
External Logical Attacks	**YES**	**NO**
Electronic mapping of network topology – external		
Gain remote access to the client's system(s) to view, copy or modify data		
Remotely copy, modify, or delete system configuration files		
Remotely view, modify, or obtain password files		
Remotely redirect traffic to or from the network		
Identify the ability to remotely deny service to computer system(s)		
Remotely deny service to computer system(s)		
Remotely reading corporate or private email		
Targeting of sensitive corporate resources		
Remote penetration of business partners		
Internal Logical Attacks	**YES**	**NO**
Electronic mapping of network topology – internal		
Gain local access to the client's system(s) to view, copy or modify data		
Locally copy, modify or delete system configuration files		
Locally view, modify or obtain password files		

Locally redirect traffic to or from the target or other portion of the network		
Identify the ability to locally deny service to computer system(s)		
Locally deny service to computer system(s)		
Locally reading corporate or private email		
Targeting of sensitive corporate resources		
Installation of software keyloggers to obtain sensitive corporate information		
Local penetration of business partners		
Physical Attacks	**YES**	**NO**
Remotely or locally adopting the identity of an employee or posing as an authorized user, member or other individual to gain physical access to sensitive data		
Breaking into employee work areas and workstations		
Remotely or locally adopting the identity of a technical supplier		
Obtaining information discarded by the client to gain information about the client (on and offsite, inside and outside "dumpster diving")		
Installation of hardware keyloggers to obtain sensitive corporate information		
Local or remote penetration of business partners		
Social Engineering Attacks	**YES**	**NO**
Obtaining sensitive corporate, customer or member information via telephone or email		
Personnel extortion, blackmail, and coercion		
Investigation of the backgrounds of staff personnel		
Phishing of employees for sensitive corporate information		
Pharming of employees for sensitive corporate information		

12. INCIDENT DETECTION AND RESPONSE

MegaCorpOne will follow normal network monitoring/intrusion detection processes and respond to any detected activity as though the activity were from an unknown, hostile source.

MegaCorpOne will retain all logs and communications pertaining to detection activities and provide copies to Supreme Security Limited for inclusion in the engagement documentation.

Supreme Security Limited will acknowledge verified detected activities.

Detected activities will not be reported to law enforcement or to any agency outside of MegaCorpOne.

13. APPREHENSION AND DETENTION

MegaCorpOne will provide each member of the Supreme Security Limited test team a "Letter of Introduction and Authorization", commonly referred to as a "Get Out of Jail Free" letter to protect members of the test team against policy violations, apprehension and/or detainment during the performance of their duties.

The letter, written on client letterhead, clearly states that the bearer is authorized to conduct social engineering, logical and physical vulnerability and penetration testing against the organization and that no crime or policy violation is being or has been committed.

Each letter will be an original copy, with blue ink signature to preclude copying and should have the designated point of contact's business card(s) attached.

These letters are distributed immediately before testing begins and collected immediately afterward. A sample of the verbiage used in these letters is provided separately from the ROE.

14. VULNERABILITY NOTIFICATION

After completion of the external discovery phase, all high and medium vulnerabilities will be verified either through additional vulnerability testing or through penetration testing. Verified high or medium external vulnerabilities will be reported to the MegaCorpOne POC immediately for corrective action. Discovered high or medium vulnerabilities that present an immediate threat to the network will be reported and verified without waiting for the end of the discovery phase.

After the completion of the internal discovery phase, all discovered high vulnerabilities will be verified either through additional vulnerability testing or through penetration testing. Verified high vulnerabilities will be reported to the MegaCorpOne POC immediately for corrective action. Discovered high vulnerabilities that present an immediate threat to the network will be reported and verified without waiting for the end of the discovery phase.

High vulnerabilities discovered during the physical penetration phase will be reported to the MegaCorpOne POC immediately for corrective action.

15. SUSPENSION OF TESTING

If Supreme Security Limited is unable to gain access to the client's systems after XXXX time or YYYY level of effort, testing will cease. If Supreme Security Limited is able to gain access, revealing the capability for exploitation, the vulnerability is documented and that portion of the testing ceases immediately. Testing will also cease if AC, in conjunction with client representatives, determines that any of the following conditions exist:

Unexpected occurrences are encountered that prohibit further testing

client reports that testing procedures materially affect computer operations in a negative manner

Once a determination has been made to suspend testing, the appropriate interested parties are informed. The justification for the suspension will be well documented using the "Memorandum of Understanding" (Appendix 1).

16. TEST MONITORING

MegaCorpOne may monitor Supreme Security Limited activities during any portion of logical testing, however testing will not be delayed due to unavailability of test monitors.

Monitors may have unrestricted access to view test sessions, screen displays and results of logical testing and verification.

If assigned, monitors must be present for all verification testing as unbiased observers that the vulnerabilities were verified.

Monitors may not accompany Supreme Security Limited personnel during physical penetration testing because their presence would compromise the test.

Internal testing will commence XXXX and end YYYY.

17. TESTING STATUS UPDATES

Supreme Security Limited will provideMegaCorpOne with in-process reviews (IPR) daily | weekly.

Immediate threats to network security will not be held pending announcement at an IPR.

18. APPROVALS

MegaCorpOne

Printed Name	
Title	
Signature	
Date	

Supreme Security Limited

Printed Name	

Title	
Signature	
Date	

Glossary

Section 1: Acronyms and Abbreviations

DD	Two digit day of month, i.e. 13 = 13th day of month
EPT	External Penetration Test
EVA	External Vulnerability Assessment
FISCAM	Federal Information system Controls Audit Manual
FISMA	Federal Information Security Management Act
IAW	In accordance with
IP	Internet Protocol
IPR	In-Process Review
IPT	Internal Penetration Test
ISO/IEC	International Organization for Standardization/International Electrotechnical Commission
ISS	Internet Security Scanner
IVA	Internal Vulnerability Assessment
MMM	Three letter abgreviation of day of week, i.e., Tue = Tuesday
NET	Not Earlier Than
NIST	National Institute of Standards and Technology
NLT	Not Later Than
POC	Point of Contact
PPT	Physical Penetration Test
ROE	Rules of Engagement
SE	Social Engineering
SEVA	Social Engineering Vulnerability Assessment
DCL	MegaCorpOne
VA	Vulnerability Assessment
VAPT	Vulnerability Assessment/Penetration Test (Team)
YY	Two-digit year, i.e., 15 = 2015

Section 2: Definitions

Black Box Penetration Test:	Black Box testing is used when the organization desires to test internal or external network security from the perspective of an outsider with no knowledge of the organization, other than that which is in the public domain and freely available to anyone. The attacker has no advance knowledge of the organization, except, perhaps, the name of the target. Black box testing most closely simulates what an organization could expect from an outside attack in that, once any discovered vulnerability is exploited and access to the network is gained, the attacker continues to exploit a specific vulnerability as far as possible, with the ultimate goal of obtaining administrative-level access to the vulnerable machine or extending network control to other machines. Because only the first successful vulnerability is exploited, other vulnerabilities within the network go untested and may leas to a false sense of security. Attacks are carried out as covertly as possible. Once the attacks are observed and reported by the target organization, black box testing ceases. Black box testing is also referred to as "no knowledge testing." It is the most unreliable form of penetration testing.
Crystal Box Penetration Test	Crystal Box testing is used when the organization desires to test internal or external network security from the perspective of an attacker with full and complete knowledge of the organization, similar to the knowledge possessed by an administrator. This knowledge normally includes passwords for routers, firewalls and IDS Systems, network topology, machine configurations and other information that an IT administrator would possess. As many discovered vulnerabilities as possible are exploited within the timeframe specified in the engagement letter. Attacks may be carried out overtly or covertly, as the organization desires. Crystal box testing provides the most thorough assessment of the security posture of the network, in that multiple attack avenues are pursued with detailed knowledge of the organization. Crystal box testing is also referred to as "full knowledge testing" or "white box testing."
Grey Box Penetration Test	Grey Box testing is used when the organization desires to test internal or external network security from the perspective of an attacker with only limited knowledge of the organization, similar to the knowledge possessed by a non-IT employee. This knowledge normally includes machine names, shared folder names, IP addresses, naming conventions and other information that a normal user with no special access would know about the target organization. As many discovered vulnerabilities as possible are exploited within the timeframe specified in the engagement letter. Attacks may be carried out overtly or covertly, as the organization desires. Grey box testing assures a more thorough

	assessment of the security posture of the network, in that several possible attack avenues are pursued. Grey box testing is also referred to as "partial knowledge testing."
Internet Foot Printing	Internet foot printing uses the Internet to search for information in the public domain that could assist an attacker in gaining access to the target's network. While some information placed in the public domain is required by law, regulation, or to assist in conducting business, excess information in the public domain could result in an attacker gaining enough knowledge to conduct logical, physical or social engineering attacks against the target. Expected results of Internet Foot Printing are: location addresses, business hours, telephone and fax numbers, contact names and e-mail addresses; partners; merger/acquisition news; privacy and security policies in place; links to other Web servers; employee names and information; networking equipment used; Web pages using input forms, assigned IP address ranges and Points of Contact, etc.
Penetration Test	The objective of penetration testing is to exploit discovered vulnerabilities to demonstrate that specific vulnerabilities, present in the organization's network, can be used to compromise network security. It uses intrusion techniques, identical or similar to methods used by attackers to breach network security, collect data and elevate the attacker's privileges within the network. It can also reveal the extent to which an organization's security incident response capability is alerted by observing the organization's response to attack methodologies.
Physical Penetration Testing	See Social Engineering
Social Engineering	Also called physical penetration testing. Social Engineering includes "successful or unsuccessful attempts to influence a person(s) into either revealing information or acting in a manner that would result in unauthorized access, unauthorized use, or unauthorized disclosure to/of an information system, network or data" using human-based or computer based techniques. In other words, using deception to con someone into providing information or access they would not normally have provided. It's the "human side" of breaking into a network and preys on qualities of human nature such as the desire to be helpful, the tendency to trust people and the fear of getting in trouble. Social engineering can also include the practices of "dumpster diving" (searching the target's refuse for useful information) and "shoulder surfing"

	(obtaining passwords by surreptitiously watching a user type in their password).
Vulnerability Assessment	The objective of vulnerability testing is to discover possible attack vectors that can be used to compromise the target network. It is a systematic examination of an information system or product to determine the adequacy of security measures, identify security deficiencies, provide data from which to predict the effectiveness of proposed security measures, and confirm the adequacy of such measures after implementation.